

Industrial Security (Bachelor)

Exercise Sheet – Section 06 Vulnerabilities and Assessment

Exercise 6.1 – Advisory Analysis

Pick a recent CISA ICS advisory and write a 1-page analysis covering:

- Vendor, product, firmware range
- Vulnerability class (CWE)
- CVSS v3.1 base score and a *justified* environmental score for a process plant
- Exploitability and impact in plain language
- Recommended mitigations (network, configuration, patch)

Exercise 6.2 – Lab: Passive Discovery

Using your OpenPLC + HMI setup from Lab 01:

1. Configure a SPAN port (or use `tcpdump` on a hub-equivalent).
2. Run a passive collector (Malcolm, Zeek, or a Python sniffer).
3. Produce an inventory: IP, MAC, vendor (OUI), open ports observed, protocols.
4. Compare with a careful active scan. Document the differences.

Exercise 6.3 – Build a Mini Risk Register

For five fictional assets (PLC, HMI, Historian, engineering laptop, vendor jump host):

1. Invent a plausible CVE for each.
2. Score with CVSS environmental.
3. Recommend mitigations and priorities (P1–P4).
4. Present as a table: *Asset, CVE, CVSS-E, Mitigation, Priority, Owner*.

Exercise 6.4 – CVSS Reasoning

A vendor advisory rates a vulnerability as CVSS 9.8. In your environment, the affected service is only reachable from a single jump host that requires MFA and is monitored.

1. Adjust CVSS attack vector / privileges accordingly. What new score do you get?
2. Does the process-impact still warrant P1, or can you defer? Justify in 5 lines.